ARX UMBRA

[Vulnerability Management Policy]

Version 1.0 · March 12, 2026

Classification: INTERNAL USE ONLY

DRAFT

§ 1. Policy Overview

This policy establishes the framework for managing vulnerabilities within **Arx Umbra**'s IT infrastructure.

Its purpose is to ensure the security and integrity of all organizational systems through timely identification, honest evaluation, and decisive remediation of threats.

— ✦ —

§ 2. Scope

This policy applies to all IT assets owned or operated by **Arx Umbra**. In-scope assets include, but are not limited to:

- Networks and network infrastructure
- Servers and virtual machines
- Endpoints and workstations
- Associated applications and services

— ✦ —

§ 3. Responsibilities

The following roles bear responsibility for the success of this program.

- Chief Information Security Officer (CISO) — Primary overseer of the vulnerability management process. Responsible for ensuring organization-wide policy compliance.
- Chief Information Officer (CIO) — Ensures vulnerability management is woven into **Arx Umbra**'s broader IT strategy.
- Chief Executive Officer (CEO) — Final sign-off authority; approves the budget.
- Department Heads: Responsible for ensuring compliance within their respective departments.

— ✦ —

§ 4. Vulnerability Scan Schedule

- Routine Scans: Scheduled, recurring, monthly scans of all in-scope IT assets.
- Ad-Hoc Scans: Triggered by significant security alerts, or when newly disclosed CVEs are reported.

— ✦ —

§ 5. Remediation Schedule and Cadence

Vulnerabilities are prioritized using the **C**ommon **V**ulnerability **S**coring **S**ystem (**CVSS**).

Critical RCE ZERO DAY (CVSS 9.0 - 10.0)	Remediate or mitigate within 48 hours.
Critical (CVSS 9.0 - 10.0)	Remediate or mitigate within 7 days.
High: (CVSS 7.0 - 8.9)	Remediate or mitigate within 2 weeks.
Medium: (CVSS 4.0 - 6.9)	Remediate or mitigate within 30 days.
Low: (CVSS 0.1 - 3.9)	Remediate or mitigate within 90 days.

— ✦ —

§ 6. Maintenance Plans

- Routine Patching: Security patches and updates applied on a monthly schedule, aligned with the scan cadence.
- Emergency Patching: Initiated within 24 hours for critical vulnerabilities posing immediate risk.
- Emergency Mitigation: Temporary measures — firewall rules, access restrictions.
- Unpatchable Assets: Legacy systems that cannot be patched will be segmented, heavily monitored, and placed on the official Phased Retirement List.

— ✦ —

§ 7. Non-Compliance Consequences

Departments failing to comply with this policy will face:

- First: An immediate review of affected procedures. We will find the gap together, professionally, without raised voices.
- Second: Mandatory retraining for involved personnel. Nobody is above learning something twice.
- Third: Escalation to senior leadership for further disciplinary action, up to and including termination. We did not want to get here. You had two chances.

— ✦ —

§ 8. Sign-Off

By signing below, the undersigned acknowledge that they have read, understood, and accepted this policy.

Chief Information Security Officer (CISO)
Name:
Sign: _____
Date: _____

Chief Information Officer (CIO)
Name:
Sign: _____
Date: _____

Chief Executive Officer (CEO)
Name:
Sign: _____
Date: _____

— ✦ —

§ 9. Review and Revision

This policy will be reviewed annually. Revisions will be version-controlled, documented, and distributed.

— ✦ —

§ Document Control

- Version: 1.1
- Date: March 12, 2026
- Author: **Arx Umbra** Security Team
- Classification: Internal Use Only
- Status: Active

❧ ⁂ ❧